LEXIGRID

Risk Stakeholders and Email Updates

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Risk Stakeholders and Email Updates **3**

Overview . . . 3

Add a contact . . . 3

Configure SMTP . . . 3

Send an update . . . 3

Security and limitations . . . 4

Email configuration operations **4**

Global configuration and roles . . . 4

Configuration procedure . . . 4

Verification without accidental send . . . 4

Error recovery . . . 4

Risk Stakeholders and Email Updates

Author: Shahryar Jahangir, Aniza Inc.

Overview

A risk may have any number of individual stakeholder contacts, each with an email address, risk role, and opt-in flag for manual email updates. Supported roles: owner, watcher, approver, auditor, reviewer. A person may hold more than one role. These labels are risk metadata and do **not** grant sign-in permissions or approval authority.

Add a contact

1. Sign in to the correct organization. Open **Risks** and click **Manage** for the risk.

2. Select **Stakeholders & Email**.

3. Enter the stakeholder's email, select a role, and optionally check **Receive email updates**.

4. Click **Add stakeholder**. Repeat for additional individuals. You may edit or remove contacts from the same screen.

Example: `security.owner@example.com` - owner - updates enabled; `audit@example.com` - auditor - updates disabled; `reviewer@example.com` - reviewer - updates enabled.

Configure SMTP

A platform administrator may save encrypted overrides in Email Configuration without restarting. Alternatively, configure these environment defaults through approved storage and restart the affected processes:

```
LEXIGRID_SMTP_HOST=mail.example.com
LEXIGRID_SMTP_PORT=587
LEXIGRID_SMTP_SECURITY=starttls
LEXIGRID_SMTP_FROM=lexigrid@example.com
LEXIGRID_SMTP_USERNAME=lexigrid@example.com
LEXIGRID_SMTP_PASSWORD=<secret provided securely>
```

`LEXIGRID_SMTP_SECURITY` supports `starttls` (usually port 587) or `ssl` (usually port 465). Never commit passwords into source control. Use a deployment secret manager where available. SMTP TLS certificate verification is enabled. Without SMTP configuration, the send operation returns a configuration error and sends nothing.

Send an update

1. Open the risk's **Stakeholders & Email** panel.

2. Confirm the intended recipients have **Receive email updates** checked.

3. Enter a concise update, such as: `Risk mitigation plan reviewed. Next control test is scheduled for Friday.`

4. Select **Send email update** and confirm.

5. LexiGrid reports how many recipients were accepted by the SMTP server. SMTP acceptance is not proof of inbox delivery.

Only tenant administrators and risk managers can send messages. Tenant administrators, risk managers, and risk editors can manage stakeholders. Other authenticated tenant users can view the stakeholder list. Every change and send attempt is audited without storing the email body in audit details.

Security and limitations

- Contacts are isolated by tenant and risk; users cannot select a risk from another tenant.

- A risk contact email is **not** an application user account. This release does not send invitations or automatically create accounts.

- Risk roles do not authorize approval actions; use the established approval workflow for formal decisions.

- Email messages contain the risk title, ID, status, and manually entered update. Avoid confidential details in email.

- No scheduled or automatic change-triggered email is implemented; updates are sent manually.

- Email recipients are passed to SMTP as envelope recipients and are not listed in the message header.

- The app cannot guarantee email delivery, read receipts, or that a recipient has a verified mailbox.

Email configuration operations

Global configuration and roles

SMTP configuration is global to the deployment, not per tenant. Platform administrators can edit browser-managed settings; tenant administrators can inspect permitted redacted status and test connectivity. Contact opt-in and queue/recovery operations remain tenant-scoped. SMTP settings never grant application permissions.

Configuration procedure

Open Email Configuration and inspect host, sender, port, security, credential presence, revision and source. Provide approved host/sender and either STARTTLS (commonly 587) or implicit TLS (commonly 465). Enter username/password as required. Leave a saved password blank to retain it; use the explicit clear control to remove it. Submit once and handle stale revision by refreshing rather than overwriting another operator's change.

The password is write-only through the UI and encrypted in the database with the existing LEXIGRID_MAIL_CONFIG_KEY. All API/scheduler/worker instances must retain that same key. A new key is not a repair for unreadable stored overrides. Database settings override environment defaults for subsequent sends; environment/worker-process changes require restart.

Verification without accidental send

Test SMTP connection and authentication performs the configured TLS/authentication checks and NOOP; it does not send an email. Verify actual delivery separately using one consenting designated recipient and an approved test risk. Confirm queue status, SMTP acceptance, any signed provider callback and optional user acknowledgement independently. A green connection test is not proof of inbox delivery.

Error recovery

For ready=false, inspect missing fields and validated mode/port/credential pairing. For failed connections, check DNS, egress, CA trust and provider policy without dumping credentials. For saved override decryption errors, restore access to the original deployment key. For queued messages, inspect worker activation and due/backoff/lease state. Browser editing does not start a stopped worker process.

Production external SMTP/provider interoperability must be qualified independently. Loopback TLS SMTP and crash/retry tests demonstrate the application's acceptance/duplicate boundary, not every provider's behavior.